PRADITA University

IT40813 · IT Governance, Risk & Compliance

KPI, KRI dan Pelaporan ke Direksi

Pertemuan 13

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. KPI, KRI, dan KCI
3. Merancang Indikator
4. Ambang dan Eskalasi
5. Portofolio Metrik
6. Mutu Data dan Manipulasi
7. Dashboard
8. Laporan ke Direksi
9. Aktivitas dan Penutup

PRADITA University

Laporan 40 halaman
sudah terbit.
Keputusan apa yang diminta?

Tujuan Pembelajaran

- Membedakan KPI, KRI, dan KCI, lalu memilih indikator yang memicu tindakan.
- Menetapkan ambang batas KRI yang selaras dengan *risk appetite*.
- Menyusun laporan GRC satu halaman yang dapat dipakai direksi untuk mengambil keputusan.

Masalah: Banyak Halaman, Tanpa Keputusan

PRADITA University

- Misalkan laporan bulanan TI setebal 40 halaman. Dengan 2 menit per halaman, satu pembaca memerlukan 80 menit.
- Pertanyaan direksi belum terjawab: apakah risiko akses vendor membaik?
- Keputusan apa yang diminta juga tidak tertulis.
- Bab 5 sudah memberi batas. Bab 8 sampai Bab 12 memberi target, kontrol, dan cara uji.
- Hasil kerja: katalog indikator, *dashboard*, dan laporan satu halaman untuk C4.

Alur dari Tujuan sampai Keputusan

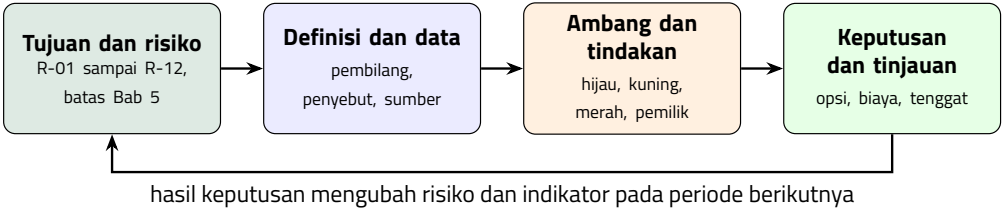


Diagram Konsep Bab 13

IT40813 / BAB 13 / DIAGRAM KONSEP

Indikator yang berbeda memicu keputusan yang berbeda



KCI tinjauan 95% dapat hijau sementara satu akun tanpa pemilik membuat KRI merah. Kedua status tidak dirata-ratakan.

Tiga Pertanyaan yang Berbeda

Jenis	Pertanyaan	Ukuran contoh	Keputusan yang dipicu
KPI	Apakah hasil tercapai?	Waktu tunggu 28 menit, target 25 menit	Alur dan jadwal petugas diubah atau dipertahankan?
KRI	Apakah paparan mendekati batas?	1 akun vendor tanpa pemilik, batas 0	Akun dibekukan atau diberi pengecualian?
KCI	Apakah kontrol dijalankan?	114 dari 120 akun ditinjau tepat waktu	Daftar diperbaiki atau peninjau ditambah?

Analogi kendaraan pengantar obat: waktu tiba menunjukkan hasil, suhu mesin menunjukkan potensi gangguan, dan buku servis menunjukkan pelaksanaan kontrol. KCI mengukur pekerjaan organisasi, sedangkan KRI mengukur keadaan yang dihadapi.

KCI Memengaruhi KRI: Hitungan R-01

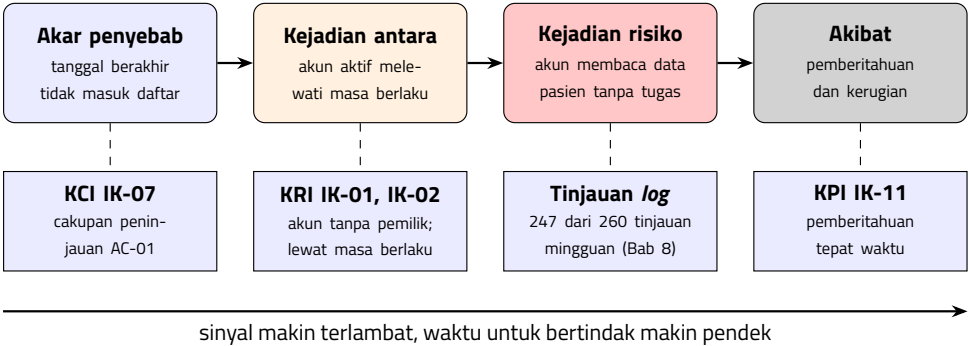
Cakupan AC-01	Peluang R-01	Harapan kerugian	Peluang rugi Rp1,5 miliar atau lebih
85 persen (Agustus)	0,0725	Rp36,25 juta	1,45 persen
90 persen (September)	0,065	Rp32,5 juta	1,3 persen
95 persen (Oktober)	0,0575	Rp28,75 juta	1,15 persen
100 persen (sasaran)	0,05	Rp25 juta	1 persen

Pengandaian kasar Bab 5: peluang $= 0{,}2 - 0{,}15\times$ cakupan. Hubungan ini bukan hukum sebab akibat. Kewajiban nol akun tanpa pemilik tetap berlaku walaupun selisih 5 persen terakhir hanya Rp3,75 juta per tahun.

Mendahului dan Tertinggal

- COSO menelusuri mundur: kejadian risiko, kejadian antara, lalu akar penyebab.
- Analogi banjir: air di bendungan hulu memberi waktu mengungsi. Rumah terendam hanya menghitung akibat.
- Mendahului: akun lewat masa berlaku naik dari 1 menjadi 5 memicu pemeriksaan (Bab 5).
- Tertinggal: pemberitahuan hanya bernilai bila ada insiden wajib.
- KRI tidak mengelola risiko. Rancangan buruk memberi rasa aman palsu.

Rantai Kejadian R-01



Pemeriksaan Keseimbangan

Perspektif	Pertanyaan	Indikator	Oktober 2026
Keuangan	Peluang kerugian besar di dalam batas?	IK-04	1 skenario di atas 2 persen
Pasien	Layanan lebih cepat dan tersedia?	IK-03, IK-12	100 menit gangguan; tunggu 28 menit
Proses internal	Kontrol berjalan dan bekerja?	IK-07, IK-08	Cakupan 95 persen; 10 dari 12 uji lulus
Pembelajaran	Temuan menghasilkan perbaikan?	IK-10	9 dari 10 tertutup

Balanced Scorecard (Kaplan dan Norton, 1992) dipakai sebagai pemeriksaan keseimbangan, bukan sebagai sistem manajemen. Bab 2: kemajuan pekerjaan 90 persen, capaian manfaat 13,3 persen.

Indikator yang Baik Menurut NIST

PRADITA University

- Penilaian menimbang terhadap kriteria. Pengukuran menghasilkan nilai kuantitatif.
- Metrik melacak kemajuan, membantu keputusan, dan memperbaiki kinerja terhadap sasaran.
- Sifatnya objektif, akurat, presisi, terikat titik waktu, dapat diulang, dan sebanding.
- Empat jenis ukuran: implementasi, efektivitas, efisiensi, dan dampak.
- Analogi nilai kelas: rata-rata 90 berbeda bila hanya menghitung siswa yang hadir.

Kartu Definisi IK-07 (Misalkan)

Unsur	Isi
Pembilang	Akun aktif yang ditinjau dalam bulan berjalan, dengan tanggal bukti
Penyebut	Semua akun aktif pada daftar penugasan: 120 akun pada 5 rumah sakit
Sumber	Daftar penugasan dan catatan peninjauan, bukan daftar dari sistem yang diperiksa
Frekuensi	Bulanan; ekstrak pada hari kerja terakhir, versi disimpan
Pemilik dan penerima	Kepala operasi TI; pemilik Medikara+ sebagai pemilik R-01
Ambang	Minimal 95 persen hijau; 90 sampai kurang dari 95 kuning; kurang dari 90 merah
Tindakan	Periksa kelengkapan daftar; koreksi kuning 5 hari kerja; merah dieskalasi
Pemeriksa mutu	Audit internal mencocokkan sampel 30 akun (Bab 12)

Penyebut Menentukan Cerita

- Laporan unit TI: 108 dari 108 akun, atau 100 persen.
- Penyebut yang benar: $108/120 = 90$ persen. Sebanyak 12 akun tidak pernah ditinjau.
- Misalkan sesudah perbaikan, pembilang diperketat menjadi tepat waktu dalam bulan itu.
- Agustus: $102/120 = 85$ persen. Angka turun karena definisi lebih ketat.
- Perubahan definisi dicatat. Tren lama tidak disambung tanpa catatan.

Nol, Tidak Berlaku, dan Data Tidak Tersedia

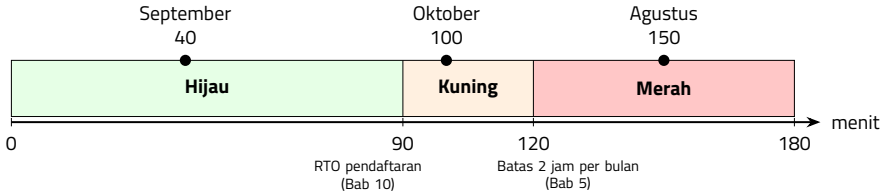
Keadaan	Contoh	Status
Nol yang sah	0 baris kewajiban lewat tenggat, register lengkap	Dinilai: hijau
Tidak berlaku	0 pemberitahuan wajib, sehingga penyebut nol	Bukan 100 persen
Data tidak tersedia	Ekstrak Bogor gagal, 20 dari 120 akun tidak terbaca	Bukan hijau

Ketepatan pemberitahuan tiga bulan adalah 1 dari 1, bukan 3 dari 3. Bila ekstrak Bogor gagal, “nol akun tanpa pemilik” hanya mencakup 100 dari 120 akun, atau 83,3 persen.

Lima Batas Bab 5 Menjadi Ambang KRI

Batas Bab 5	KRI	Ambang	Tindakan
Kerahasiaan: nol akun vendor tanpa pemilik dan masa berlaku	IK-01, IK-02	0 hijau; lebih dari 0 merah	Validasi 1 hari kerja, bekukan
Kelangsungan: pendaftaran terganggu paling lama 2 jam per bulan	IK-03	Sampai 90 menit hijau; sampai 120 kuning; di atasnya merah	Siapkan perbaikan; tinjauan mingguan
Finansial: peluang kerugian Rp1,5 miliar atau lebih paling tinggi 2 persen	IK-04	0 skenario hijau; lebih dari 0 merah	Laporkan ke komite
Kepatuhan: nol baris K-01 sampai K-16 lewat tenggat tanpa keputusan	IK-05	0 hijau; lebih dari 0 merah	Catat penyimpangan
Keselamatan: risiko cedera berat ditinjau dalam 1 hari kerja	IK-06	0 terlambat hijau; lebih dari 0 merah	Libatkan pimpinan klinis

Zona Ambang IK-03



Satu kejadian yang memenuhi RTO 90 menit menyisakan 30 menit. Rata-rata tiga bulan 96,7 menit menyembunyikan pelanggaran Agustus, karena batas Bab 5 berbunyi per bulan.

Toleransi Nol dan Aturan Tepi

- Tren 3, 2, 1 tetap merah sampai nol. Zona kuning buatan melunakkan batas.
- Peringatan dini berpindah ke IK-02 dan IK-07.
- Pengecualian darurat dicatat terpisah. Sesudah 24 jam, akun masuk hitungan IK-01.
- Status memakai nilai sebelum pembulatan: $113/120 = 94{,}17$ persen berstatus kuning.
- Populasi kecil: 5 DPIA berarti satu butir 20 persen, sehingga ambang kuning 80 persen.

Jalur Eskalasi Memakai Batas Delegasi Bab 2

Tingkat	Pemicu	Waktu
Pemilik tindakan	Nilai kuning atau merah	Merah 1 hari kerja; kuning 5 hari kerja
Pemilik risiko	Merah belum tertutup; butuh pengecualian	Hari kerja berikutnya; pengecualian paling lama 24 jam
Kepala TI	Biaya sampai Rp100 juta	Ringkasan triwulan ke komite
Komite pengarah TI	Di atas Rp100 juta sampai Rp400 juta; merah dua bulan berturut-turut	Rapat bulanan
Direksi	Di atas Rp400 juta sampai Rp5 miliar; penerimaan risiko di atas batas	Triwulan, atau segera bila pemicu krisis organisasi terpenuhi
Dewan komisaris	Di atas Rp5 miliar, bila anggaran dasar menetapkan	Laporan triwulan

IK-06 langsung melibatkan pimpinan klinis. Pemberitahuan K-04 mengikuti jam insiden Bab 7.

Kasus Medikara: Satu Akun pada Oktober

PRADITA University

- Misalkan ekstrak Oktober menemukan 1 akun tanpa pemilik, divalidasi dalam 1 hari kerja.
- Pemilik Medikara+ membekukan akun dan menolak pengecualian 24 jam.
- Biaya: pekerjaan teknisi tertunda 1 hari kerja.
- IK-01 tetap merah pada laporan, karena nilainya keadaan pada tanggal data.
- Rekonsiliasi sampai Rp60 juta di bawah batas Rp100 juta: kepala TI yang memutuskan.

Memilih dari Pertanyaan, Bukan dari Data

PRADITA University

- NIST: metrik yang salah pilih merusak mutu laporan. Pada tahap awal, lebih sedikit sering lebih baik.
- Uji: apakah data menggambarkan kinerja kontrol, atau melacak risiko yang material?
- Analogi pemeriksaan kesehatan: tiap angka punya batas dan tindak lanjut.
- Kasus: 46 usulan, 19 gugur, 15 tingkat operasional, 12 indikator.
- CSF GV.OV-03: kinerja pengelolaan risiko dievaluasi dan ditinjau untuk penyesuaian.

Portofolio Dua Belas Indikator (Misalkan)

PRADITA University

Kode	Indikator	Jenis	Pemilik tindakan	Kaitan
IK-01	Akun vendor aktif tanpa pemilik atau masa berlaku	KRI	Kepala operasi TI	R-01, AC-01
IK-02	Akun melewati masa berlaku	KRI	Kepala operasi TI	R-01, AC-01
IK-03	Menit gangguan pendaftaran	KRI	Kepala operasi TI	R-03, R-05
IK-04	Skenario melewati batas peluang kerugian	KRI	Kepala risiko	R-01, R-05
IK-05	Baris kewajiban lewat tenggat tanpa keputusan	KRI	Fungsi kepatuhan	K-01 sampai K-16
IK-06	Risiko cedera berat lewat tinjauan 1 hari kerja	KRI	Pimpinan klinis	R-11
IK-07	Cakupan peninjauan AC-01	KCI	Kepala operasi TI	R-01, AC-01
IK-08	Uji pemulihan lulus, gabungan dan rumah sakit	KCI	Kepala operasi TI	R-05, K-02
IK-09	DPIA selesai	KCI	Petugas pelindungan data	5 DPIA Bab 7
IK-10	Temuan tertutup tepat waktu sesudah uji ulang	KPI	Pemilik tiap temuan	TA-01 dan lainnya
IK-11	Pemberitahuan tepat waktu	KPI	Petugas pelindungan data	R-12, K-04
IK-12	Waktu tunggu pendaftaran 18 klinik	KPI	Kepala pendaftaran	Bab 1 dan Bab 2

Bahan dari Bab 8 sampai Bab 12

Asal	Bahan	Diolah menjadi	Pembaca
Bab 8	T-19: 247 dari 260 tinjauan *log* mingguan, 95 persen	KCI jejak aktivitas	Komite pengarah TI
Bab 9	Akun vendor tanpa pemilik, 0 akun	IK-01	Direksi bila merah
Bab 9	Catatan AC-01, 60 dari 60 per tahun atau 5 per bulan	Rincian IK-07	Pemilik risiko
Bab 9	Laporan dugaan insiden vendor 12 jam, K-05	Masuk IK-05 bila lewat tenggat tanpa keputusan	Komite risiko
Bab 9	Latihan bersama 2 per tahun; subprosesor 30 hari; uji ekspor 1 per tahun	Kalender kontrol	Pengelola vendor
Bab 10	RTO 90 menit; 29 dari 36 uji; 3 dari 5 rumah sakit	IK-03, IK-08	Direksi
Bab 11	27 dari 30 kasus darurat tertangkap; 93 dari 120 tanda klinik keliru; AI-03 selisih 8, ambang 5	KCI mutu AI; jalur penyebab R-11 pada IK-06, tanpa kode baru	Komite risiko
Bab 12	TA-01; 24 dari 30 akun sesuai; kriteria 30 dari 30	IK-10; pemeriksa mutu IK-07	Direksi bila lewat tenggat

SLO disinggung saja. Layanan pesan 99,5 persen dari 8.760 jam dan batas pendaftaran 24 jam dari 4.380 jam memiliki dasar hitung berbeda, sehingga tidak digabung.

Sumber Data dan Mutu Data

- NIST: validitas diragukan bila sumber hanya memuat sebagian unit atau proses tidak konsisten.
- COSO: tanpa keseragaman cara ukur, data gabungan menambah gangguan pada keputusan.
- Analogi timbangan pasar: harga antarkios tidak sebanding bila timbangan berbeda.
- Laporan 18 klinik: 2 jam per klinik per bulan menjadi 432 jam per tahun, Rp25,92 juta.
- R-04: versi spreadsheet berbeda, harapan kerugian Rp30 juta per tahun.

Indikator yang Dimanipulasi

Bentuk	Contoh	Pengaman
Mengecilkan penyebut	12 akun keluar dari daftar, 90 menjadi 100 persen	Populasi dari daftar penugasan
Memindahkan kategori	Insiden wajib dicatat tidak wajib	Alasan ditinjau fungsi hukum
Menutup di atas kertas	Selesai menurut manajemen: 100 persen; lolos uji ulang: 90 persen	Hitung sesudah uji ulang
Mengejar batas	Peninjauan tergesa supaya tepat 95 persen	Sampel mutu; catatan per akun
Mengubah definisi	Tepat waktu digeser dari 30 menjadi 45 hari	Riwayat definisi; tren tidak disambung

Bevan dan Hood (2006): tata kelola lewat target mengandaikan bagian mewakili keseluruhan, serta masalah pengukuran dan *gaming* tidak penting. Contoh: 125 menit gangguan menjadi 85 menit karena 40 menit disebut pemeliharaan.

Dashboard: Keadaan, Tren, dan Pengecualian

PRADITA University

- Few: informasi terpenting pada satu layar, dapat dipantau sekilas.
- *Dashboard* memberi tahu apa yang terjadi, bukan mengapa.
- Analogi papan keberangkatan: kereta, jam, dan status. Alasan dicari di tempat lain.
- Warna selalu disertai angka dan kata status. Pengecualian ditaruh lebih dahulu.
- Tiga nilai terakhir terlihat. Perubahan definisi diberi catatan.

Dashboard GRC, Oktober 2026 (Misalkan)

IK-01 Akun tanpa pemilik **1 akun** MERAH 3, 2, 1	**IK-04 Skenario lewat batas** **1 (R-05)** MERAH 1, 1, 1	**IK-08 Uji pemulihan** **83,3%** MERAH rumah sakit 1 dari 2 75%, 83,3%, 83,3%	**IK-03 Gangguan pendaftaran** **100 menit** KUNING 150, 40, 100
IK-12 Waktu tunggu **28 menit** KUNING 34, 31, 28	**IK-02 Lewat masa berlaku** **0 akun** HIJAU 2, 1, 0	**IK-05 Kewajiban lewat tenggat** **0 baris** HIJAU 2, 1, 0	**IK-06 Cedera lewat tinjauan** **0 laporan** HIJAU 0, 1, 0
IK-07 Cakupan AC-01 **95%** HIJAU 85%, 90%, 95%	**IK-09 DPIA selesai** **100%** HIJAU 60%, 80%, 100%	**IK-10 Temuan tertutup** **90%** HIJAU 60%, 80%, 90%	**IK-11 Pemberitahuan** **Nol kewajiban** TIDAK BERLAKU 100%, lalu tidak berlaku

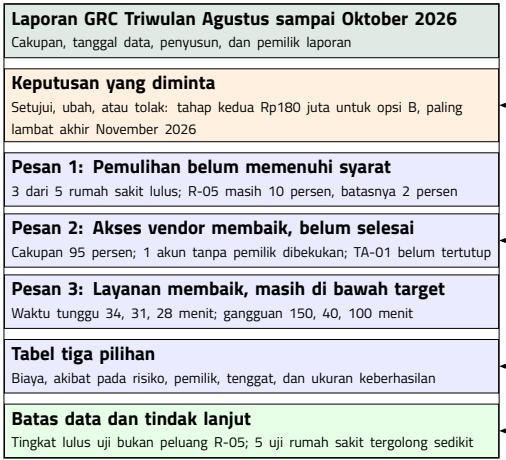
Tren Dua Belas Indikator (Misalkan)

Indikator	Agustus	September	Oktober
IK-01 Akun tanpa pemilik	3, merah	2, merah	1, merah
IK-02 Lewat masa berlaku	2, merah	1, merah	0, hijau
IK-03 Gangguan pendaftaran	150 menit, merah	40 menit, hijau	100 menit, kuning
IK-04 Skenario lewat batas	1, merah	1, merah	1, merah
IK-05 Kewajiban lewat tenggat	2, merah	1, merah	0, hijau
IK-06 Cedera lewat tinjauan	0, hijau	1, merah	0, hijau
IK-07 Cakupan AC-01	102/120 = 85%, merah	108/120 = 90%, kuning	114/120 = 95%, hijau
IK-08 Uji pemulihan	9/12 = 75%; rumah sakit 1/2, merah	10/12 = 83,33%; 1/1, kuning	10/12 = 83,33%; 1/2, merah
IK-09 DPIA selesai	3/5 = 60%, merah	4/5 = 80%, kuning	5/5 = 100%, hijau
IK-10 Temuan tertutup	6/10 = 60%, merah	8/10 = 80%, kuning	9/10 = 90%, hijau
IK-11 Pemberitahuan	1/1 = 100%, hijau	Tidak berlaku	Tidak berlaku
IK-12 Waktu tunggu	34 menit, merah	31 menit, merah	28 menit, kuning

Mengapa Tanpa Skor Gabungan

- Misalkan hijau 100, kuning 50, merah 0, dan tidak berlaku dikeluarkan.
- Skor gabungan: 16,7, lalu 27,3, lalu $700 \div 11 \approx 63{,}6$.
- Skor naik hampir empat kali lipat, sementara IK-01 dan IK-04 merah pada ketiga bulan.
- Hijau dan merah tidak dirata-ratakan menjadi kuning.
- Harganya: satu baris lebih untuk tiap pengecualian, tanpa satu angka yang mudah diingat.

Struktur Laporan Satu Halaman



Isi dan Alamat Laporan

- NIST: ukuran tanpa konteks menimbulkan keraguan. Sebutkan risiko, batas, dan tindakan.
- COSO: frekuensi mengikuti pembaca. Direksi membaca yang teragregasi.
- Medikara: *dashboard* bulanan ke komite, laporan triwulan ke direksi (Bab 2).
- Daftar 7 kegiatan selesai tidak memberi dasar bertindak.
- Rp60 juta salah alamat bila dibawa ke direksi. Rp180 juta tahap kedua milik direksi.

Kasus Medikara: Tiga Pesan

- Pesan 1: pemulihan belum memenuhi syarat. 29 dari 36 uji lulus, 3 dari 5 rumah sakit, 2 data gagal dari 9 uji akun terpisah. R-05 masih 10 persen, batasnya 2 persen.
- Pesan 2: akses vendor membaik, belum selesai. Cakupan 85, 90, 95 persen. Satu akun dibekukan. TA-01 belum lolos uji ulang.
- Pesan 3: layanan membaik, masih di bawah target. Waktu tunggu 34, 31, 28 menit. Gangguan Oktober 100 menit, di atas RTO 90 menit.

Kasus Medikara: Satu Keputusan

Pilihan	Biaya	Akibat pada R-05	Risiko pilihan
1. Tahan tahap kedua; uji ulang 2 rumah sakit dan 9 uji akun terpisah	Rp0 tambahan saat ini	Peluang tetap 0,1; sekitar Rp40 juta lebih tinggi per triwulan	Direksi menerima tertulis paparan di atas batas selama satu triwulan
2. Cairkan Rp180 juta sekarang	Rp180 juta	Peluang tetap dicatat 0,1 sampai uji lulus	Syarat hilang; uang keluar sebelum bukti
3. Hentikan opsi B, kembali ke opsi A	Hemat Rp180 juta	SIMRS pulih 480 menit; batas 2 persen dilanggar	Sudah ditolak pada Bab 10

Rekomendasi pilihan 1, keputusan paling lambat akhir November 2026. Keberhasilan: 5 dari 5 rumah sakit di bawah 120 menit, dan 9 dari 9 uji akun terpisah, paling lambat akhir Januari 2027.

Beban Laporan Lama dan Rancangan Baru

Unsur	Laporan 40 halaman	Satu halaman
Penyusunan per tahun	$(8 \times 6 + 16) \times 12 = 768$ jam	$12 \times 2 \times 12 + 4 \times 24 = 384$ jam
Biaya per tahun	Rp46,08 juta	Rp23,04 juta
Waktu baca	80 menit, 12 kali	Sekitar 5 menit, 4 kali

Penghematan 384 jam berarti indikator tidak menambah beban 3.046 jam pada Bab 14. Rincian tetap tersedia di *dashboard* dan katalog bagi pihak yang bertugas memakainya.

Aktivitas: Langkah Kerja

1. Pilih 8 sampai 12 indikator. Tulis keputusan yang didukung tiap ukuran.
2. Isi katalog: rumus, sumber, frekuensi, pemilik, serta ambang tiga warna.
3. Hitung tiga periode. Bedakan nol, tidak berlaku, dan data tidak tersedia.
4. Susun *dashboard* pada spreadsheet, lalu tulis tiga pesan dan satu keputusan.
5. Tinjau silang rumus, lalu simulasikan rapat 5 menit.

Aktivitas: Peran, Luaran, dan Penilaian

PRADITA University

- Peran: analis risiko memimpin ambang, anggota bisnis menyusun narasi, analis teknologi memeriksa data, pemilik konteks memeriksa kewenangan.
- Luaran masuk C4: katalog, *dashboard*, dan laporan satu halaman.
- Kriteria: risiko dan keputusan 30 persen; definisi dan hitungan 30 persen; ambang 20 persen; permintaan keputusan 20 persen.
- Berkas: `sources/chapter13/README.md`.
- Opsional: mengotomasi dua indikator ke Metabase atau Grafana.

Ringkasan

- KPI, KRI, dan KCI menjawab hasil, paparan, dan kontrol. Warnanya tidak dirata-ratakan.
- Definisi menentukan cerita: 108 dari 108 berbeda dari 108 dari 120.
- Ambang diturunkan dari batas Bab 5. Toleransi nol tetap merah sampai nol.
- *Dashboard* menunjukkan keadaan dan tren. Laporan mengajukan pilihan.
- Indikator berguna ketika mengubah keputusan dan tindakan, bukan ketika memenuhi halaman.

Latihan

1. “Jumlah pelatihan keamanan yang diselenggarakan” diusulkan sebagai KRI. Kritisi usulan ini dan tawarkan indikator yang lebih baik.
2. Turunkan ambang KRI untuk risiko kontrol akses dari pernyataan *risk appetite* yang dibuat pada Pertemuan 5.
3. Jelaskan apa yang membuat sebuah laporan direksi berujung pada keputusan, bukan sekadar dibaca.

Contoh terisi dan lembar isian ada pada modul.

Bacaan dan Berkas Pendukung

PRADITA University

- NIST SP 800-55 Volume 1 dan Volume 2
- NIST CSF 2.0
- COSO: Developing Key Risk Indicators
- Bevan dan Hood (2006) dan Few (2004)
- `sources/chapter13/README.md`